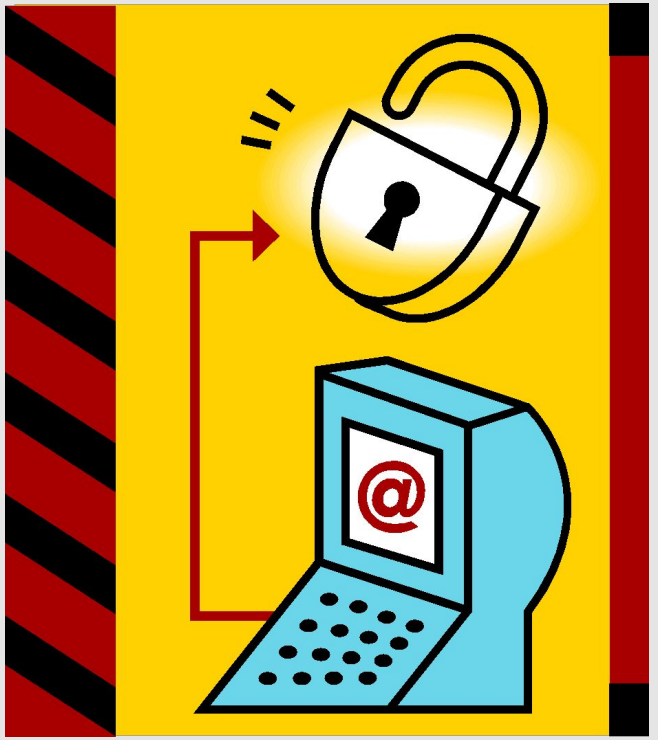
Information Security Overview



Network Security

Consists of measures to deter, prevent, detect, and correct security violations that involve the transmission of information



CIA Triad

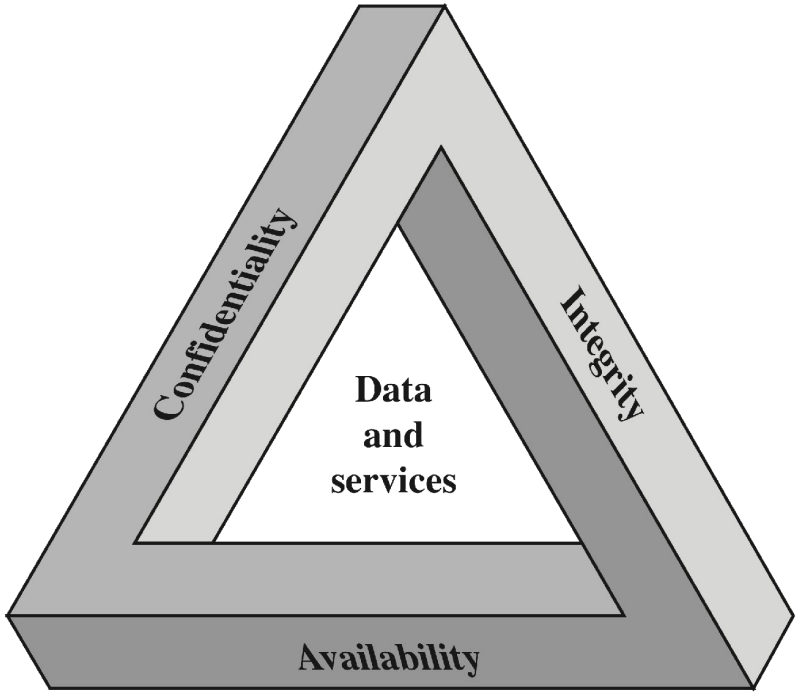


Figure 1.1 The Security Requirements Triad

Computer Security Objectives

Confidentiality

- Data confidentiality
  - Assures that private or confidential information is not made available or disclosed to unauthorized individuals
- Privacy
  - Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed

Integrity

- Data integrity
  - Assures that information and programs are changed only in a specified and authorized manner
- System integrity
  - Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system

Availability

- Assures that systems work promptly, and service is not denied to authorized users

Possible additional concepts:

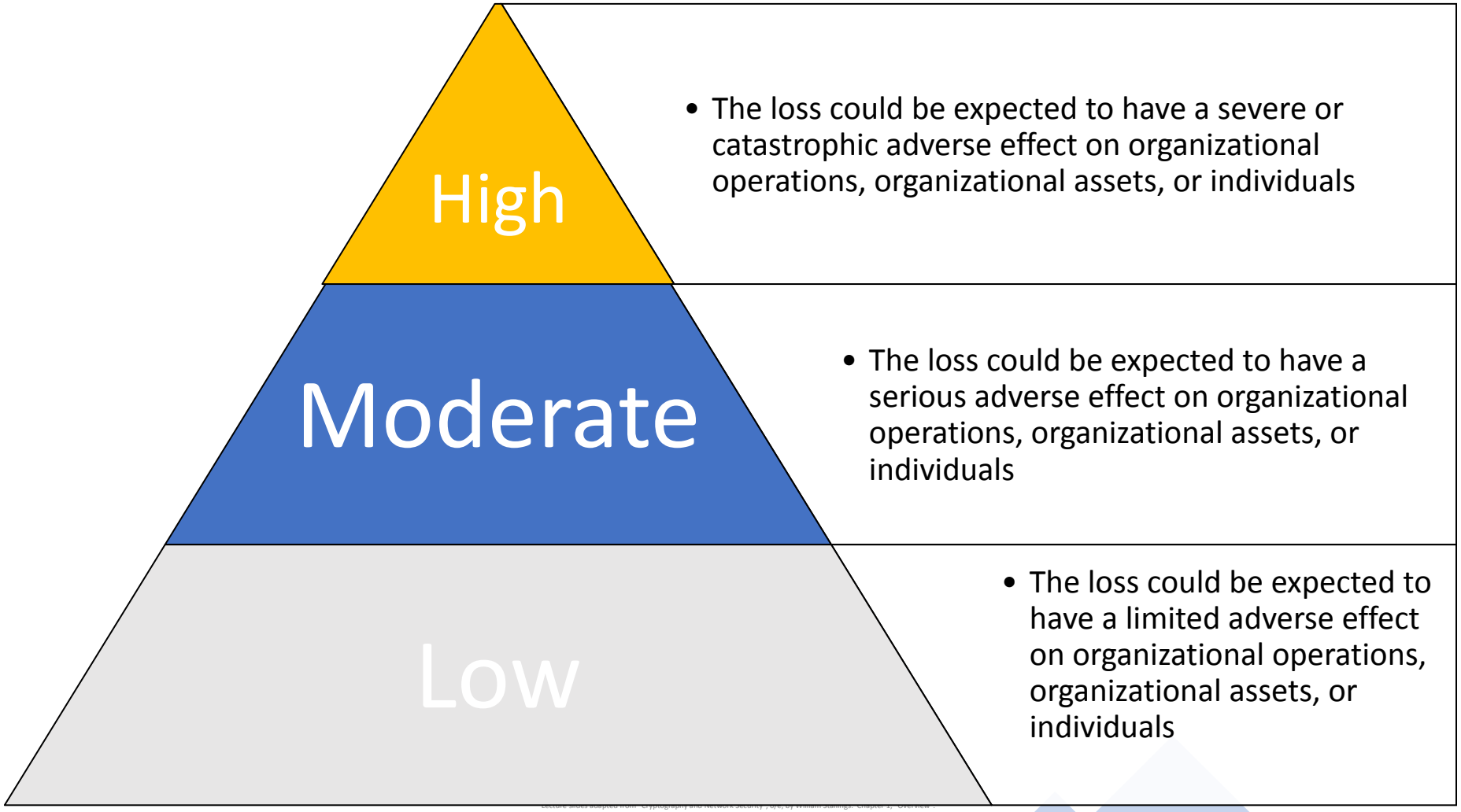
Authenticity

- Verifying that users are who they say they are and that each input arriving at the system came from a trusted source

Accountability

- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity

Breach of Security / Levels of Impact



Cryptographic algorithms and protocols can be grouped into four main areas:

Symmetric encryption

- Used to conceal the contents of blocks or streams of data of any size, including messages, files, encryption keys, and passwords

Asymmetric encryption

- Used to conceal small blocks of data, such as encryption keys and hash function values, which are used in digital signatures

Data integrity algorithms

- Used to protect blocks of data, such as messages, from alteration

Authentication protocols

- Schemes based on the use of cryptographic algorithms designed to authenticate the identity of entities

Computer Security Challenges

- Security is not simple
- Potential attacks on the security features need to be considered
- Procedures used to provide particular services are often counter-intuitive
- It is necessary to decide where to use the various security mechanisms
- Requires constant monitoring
- Is too often an afterthought

- Security mechanisms typically involve more than a particular algorithm or protocol
- Security is essentially a battle of wits between an offender and the designer
- Little benefit from security investment is perceived until a security failure occurs
- Strong security is often viewed as a barrier to efficient and user-friendly operation

OSI Security Architecture

- **Security attack**
  - Any action that compromises the security of information owned by an organization
- **Security mechanism**
  - A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack
- **Security service**
  - A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization
  - Intended to counter security attacks, and they make use of one or more security mechanisms to provide the service

Table 1.1
Threats and Attacks (RFC 4949)



Threat

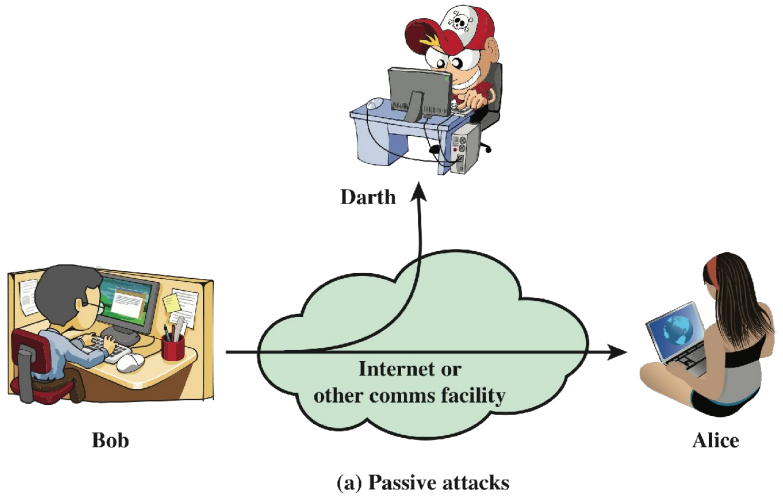
A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Attack

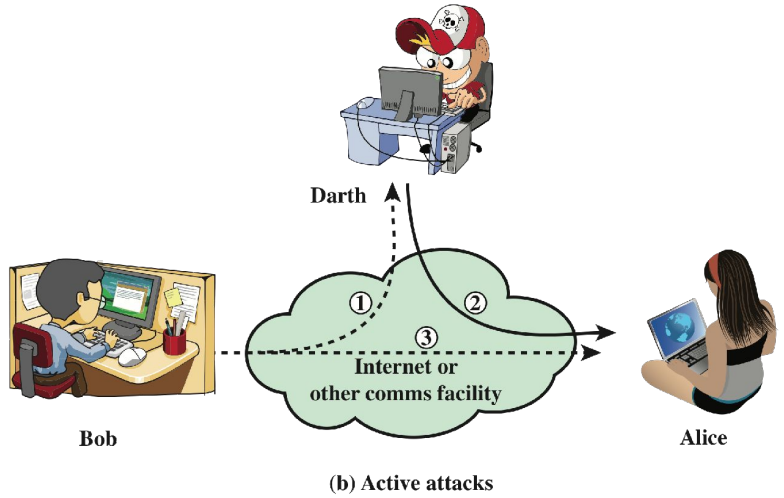
An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and violate the security policy of a system.

Security Attacks

- A means of classifying security attacks, used both in X.800 and RFC 4949, is in terms of *passive attacks* and *active attacks*
- A *passive attack* attempts to learn or make use of information from the system but does not affect system resources
- An *active attack* attempts to alter system resources or affect their operation



(a) Passive attacks



(b) Active attacks

Figure 1.1 Security Attacks

Passive Attacks

- Are in the nature of eavesdropping on, or monitoring of, transmissions
- Goal of the opponent is to obtain information that is being transmitted
- Two types of passive attacks are:
  - The release of message contents
  - Traffic analysis



Active Attacks

- Involve some modification of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities
- Goal is to detect attacks and to recover from any disruption or delays caused by them



Masquerade	• Takes place when one entity pretends to be a different entity • Usually includes one of the other forms of active attack
Replay	• Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect
Modification of messages	• Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect
Denial of service	• Prevents or inhibits the normal use or management of communications facilities

Lecture slides adapted from "Cryptography and Network Security", 6/e, by William Stallings. Chapter 1, "Overview".

Security Services

- Defined by X.800 as:
  - A service provided by a protocol layer of communicating open systems and that ensures adequate security of the systems or of data transfers
- Defined by RFC 4949 as:
  - A processing or communication service provided by a system to give a specific kind of protection to system resources

X.800 Service Categories

- Authentication
- Access control
- Data confidentiality
- Data integrity
- Nonrepudiation



Authentication

Two specific authentication services are defined in X.800

- Peer Entity Authentication
  - Used when a communication is established and during data transfer
  - Ensures that a communication is authentic
    - In the case of ongoing interaction, assures the two entities are authentic and that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties
- Data-origin Authentication
  - Assures the recipient that the message is from the source that it claims to be from

Access Control

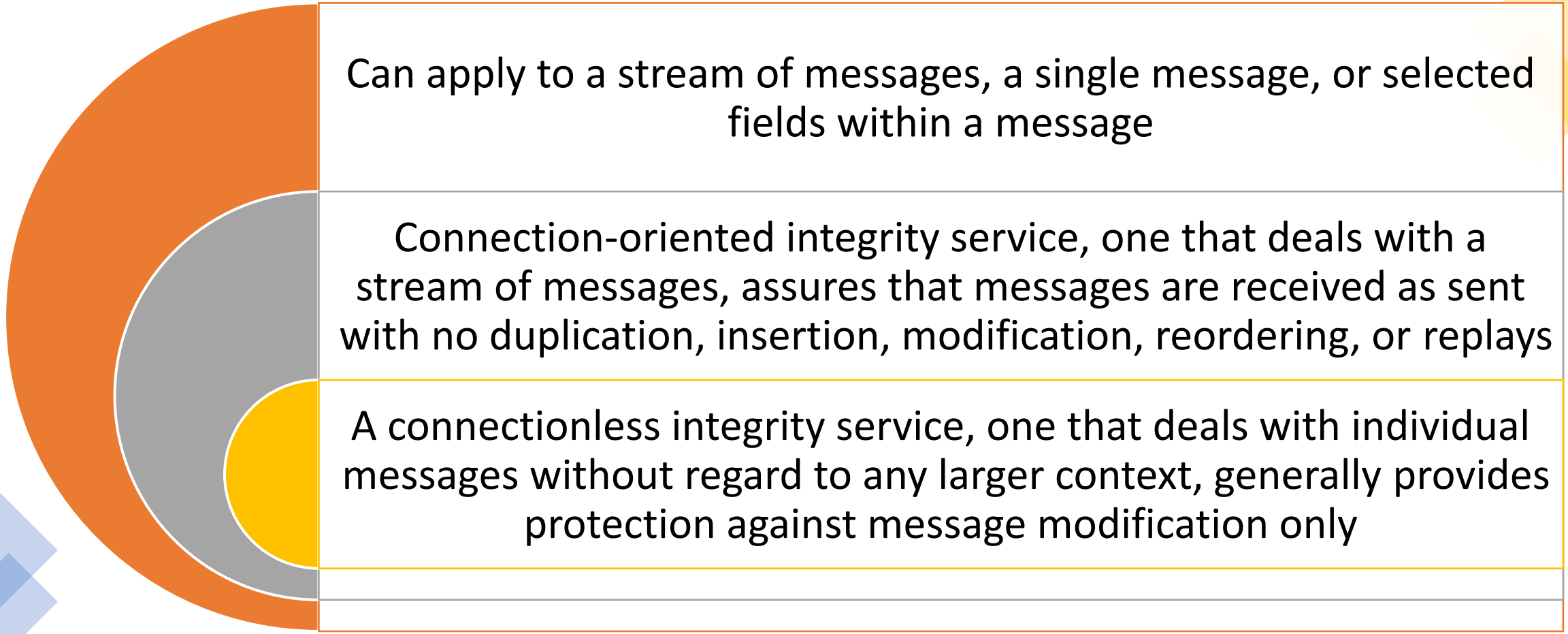
- The ability to limit and control the access to host systems and applications via communications links
- To achieve this, each entity trying to gain access must first be indentified, or authenticated, so that access rights can be tailored to the individual



Data Confidentiality

- The protection of transmitted data from passive attacks
  - Broadest service protects all user data transmitted between two users over a period of time
  - Narrower forms of service includes the protection of a single message or even specific fields within a message
- The protection of traffic flow from analysis
  - This requires that an attacker not be able to observe the source and destination, frequency, length, or other characteristics of the traffic on a communications facility

Data Integrity



Nonrepudiation



PREVENTS EITHER SENDER OR RECEIVER FROM DENYING A TRANSMITTED MESSAGE



WHEN A MESSAGE IS SENT, THE RECEIVER CAN PROVE THAT THE ALLEGED SENDER IN FACT SENT THE MESSAGE



WHEN A MESSAGE IS RECEIVED, THE SENDER CAN PROVE THAT THE ALLEGED RECEIVER IN FACT RECEIVED THE MESSAGE

Security Mechanisms



Security mechanisms are used to provide and support Security services



Two types of mechanisms

Specific Security Mechanisms – used to provide specific security services

Pervasive Security Mechanisms – not specific to a particular service

Specific Security Mechanisms

Encryption - encryption or cipher algorithms that provide data confidentiality

Digital signature - Signing, verification, non repudiation, origin authentication and data integrity

Access control mechanisms - Controlling access to resources

Data integrity mechanisms - Provides data integrity and origin authentication services

Authentication exchanges - Entity authentication

Traffic padding - Padding data to provide data confidentiality

Routing control - Providing secure channels for routing data

Notarization - Using notary or a crypto graphical transformation to guarantee data integrity

Pervasive Security Mechanisms

- **Trusted Functionality**
  - Any functionality (software or hardware) providing or accessing security mechanisms should be trustworthy
- **Security Labels**
  - Using security labels with any kind of resource for eg: stored data to indicate it is security sensitive
  - Could also be associated with user data
- **Event detection**
  - Used to detect violations or legal security related activity
  - Could be used to trigger security alarms or event logging
- **Security audit trail**
  - Log of past security related events
- **Security Recovery**
  - Mechanisms to handle requests to recover from security failures

Model for Network Security

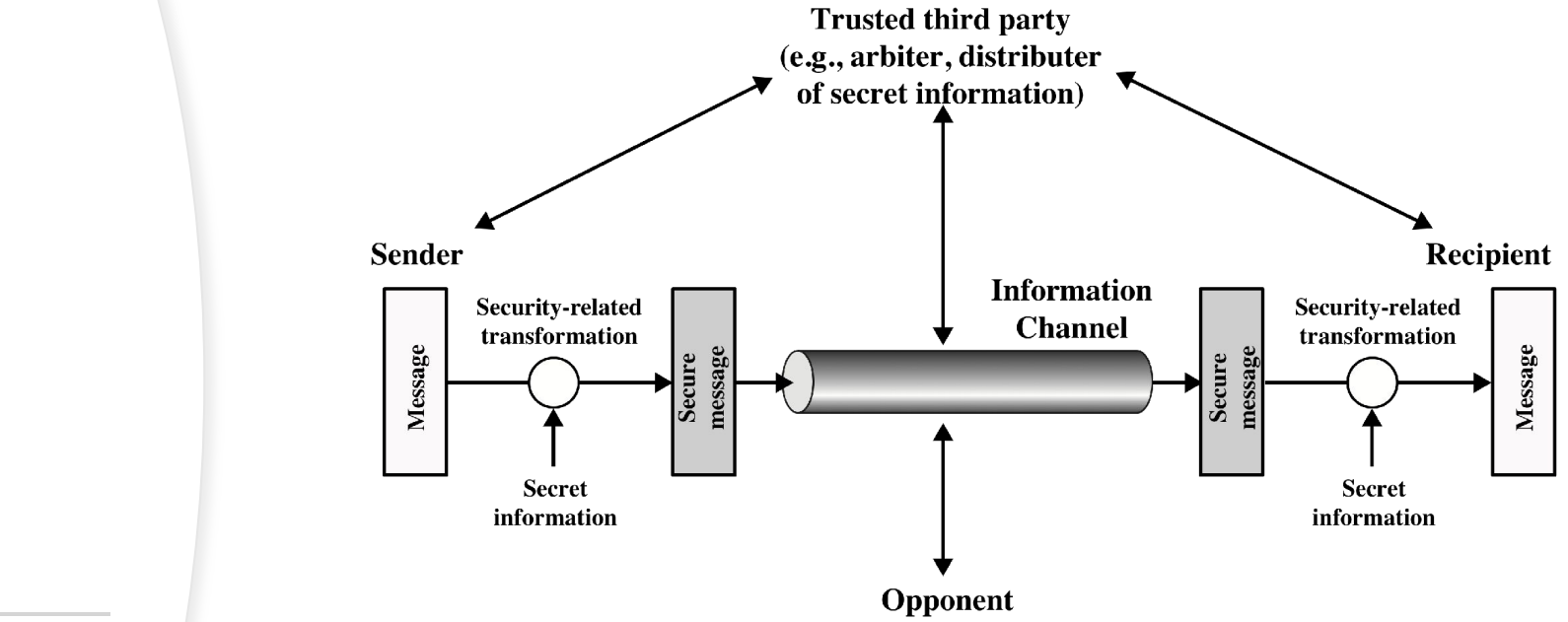


Figure 1.2 Model for Network Security

Designing a security service

- Includes four basic tasks:
  - Design a strong algorithm for performing security related transformation
  - Generate the secret information to be used with the algorithm
  - Develop methods for distribution and sharing of the secret information
  - Specify the protocol to be used by both sender and receiver
    - Makes use of the security algorithm and the secret information
    - Achieves the security service



Network Access Security Model

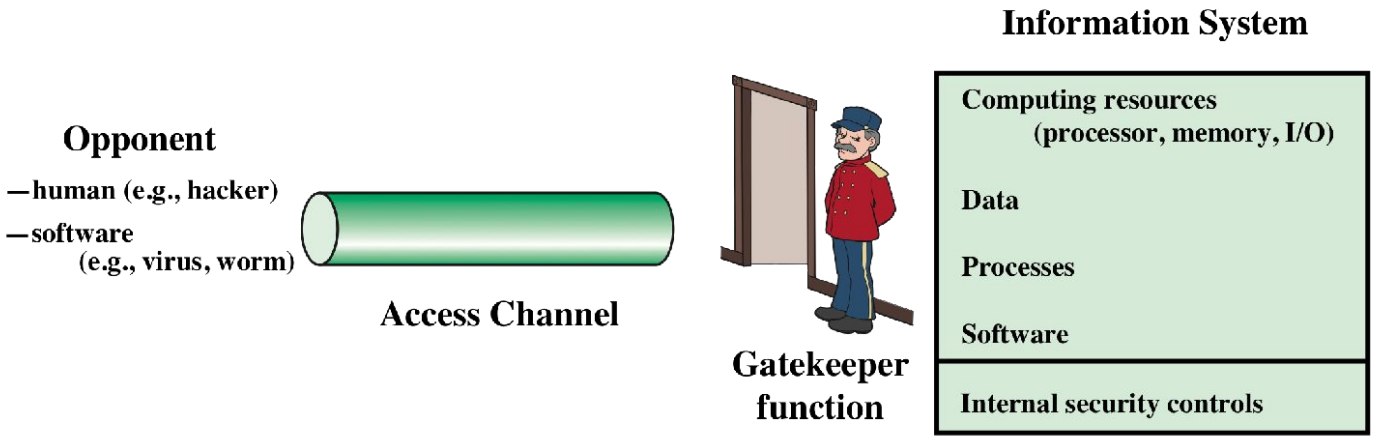


Figure 1.3 Network Access Security Model

Unwanted Access

- Placement in a computer system of logic that exploits vulnerabilities in the system and that can affect application programs as well as utility programs such as editors and compilers
- Programs can present two kinds of threats:
  - **Information access threats**
    - Intercept or modify data on behalf of users who should not have access to that data
  - **Service threats**
    - Exploit service flaws in computers to inhibit use by legitimate users



Summary

- Computer security concepts
  - Definition
  - Examples
  - Challenges
- The OSI security architecture
- Security attacks
  - Passive attacks
  - Active attacks
- Security services
  - Authentication
  - Access control
  - Data confidentiality
  - Data integrity
  - Nonrepudiation
  - Availability service
- Security mechanisms

Class Activity-1

- Please classify each of the following as a violation of confidentiality, integrity, availability, authenticity, or some combination of these

- John copies Mary’s homework.
- Paul crashes Linda’s system.
- Gina forges Roger’s signature on a deed.